
CLOUD APPLICATION SECURITY

Mbong Hudson
Infrastructure Engineer - CCNP, AWS, CISSP

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

BUILDING SECURE CLOUD APPLICATIONS

1. **Application Design & Architecture:** Cloud-specific design principles, scalability, resilience, and security considerations.
2. **Application Testing & Validation:** Validation techniques, threat modelling, secure software acquisition, testing, and supply chain security. Software Development Lifecycle (SDLC) models and best practices.
3. **Tools for Cloud Application Security:** Building, deployment, and security tools. Focus on Cloud Application Security Brokers (CASBs).
4. **Identity & Access Management (IAM):** Authentication, authorisation, Single Sign-On (SSO), Multi-factor Authentication (MFA), Federation, and Identity Providers.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

BUILDING SECURE CLOUD APPLICATIONS

1. **Application Design & Architecture:** Cloud-specific design principles, scalability, resilience, and security considerations.
2. **Application Testing & Validation:** Validation techniques, threat modelling, secure software acquisition, testing, and supply chain security. Software Development Lifecycle (SDLC) models and best practices.
3. **Tools for Cloud Application Security:** Building, deployment, and security tools. Focus on Cloud Application Security Brokers (CASBs).
4. **Identity & Access Management (IAM):** Authentication, authorisation, Single Sign-On (SSO), Multi-factor Authentication (MFA), Federation, and Identity Providers.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

DEVELOPING SOFTWARE FOR THE CLOUD

Mbong Hudson
Infrastructure Engineer - CCNP, AWS, CISSP

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

INTRO TO CLOUD SOFTWARE DEVELOPMENT

- Cloud software shares similarities with traditional development but differs in infrastructure and scalability.
- Key focus: scalability, performance, CI/CD, and DevOps/DevSecOps practices.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

KEY CLOUD DEVELOPMENT CONSIDERATIONS

- **Scalability:** Ability to handle fluctuating workloads.
- **Performance:** Ensuring optimal application responsiveness.
- **Security:** Implementing secure coding practices.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

COMMON CLOUD DEPLOYMENT PITFALLS

- Cloud Lock-in
- Regional Availability Issues
- Inefficient Performance Design

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

PERFORMANCE IN CLOUD SOFTWARE

- Cloud applications rely on loosely coupled services.
- Complex interactions can impact performance.
- Proper architecture enables high scalability.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SCALABILITY IN THE CLOUD

- Cloud enables auto-scaling of resources.
- Applications must handle multiple instances.
- Secure data transmission is crucial.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

INTEROPERABILITY AND PORTABILITY

- Interoperability ensures compatibility across platforms.
- Portability prevents vendor lock-in.
- Avoid reliance on vendor-specific APIs.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

AVAILABILITY AND RELIABILITY

- Cloud providers offer high uptime but outages still occur.
- Dependencies on third-party services can cause failures.
- Designing for redundancy enhances reliability.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

API SECURITY IN CLOUD APPLICATIONS

- APIs are integral to cloud applications.
- Secure API design prevents vulnerabilities.
- Encryption and authentication are essential.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CONCLUSION AND BEST PRACTICES

- Design for scalability and performance.
- Implement security from the start.
- Plan for interoperability and portability.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CLOUD APPLICATION ARCHITECTURE

Mbong Hudson
Infrastructure Engineer - CCNP, AWS, CISSP

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

THE BUILDING BLOCKS OF CLOUD APPLICATIONS

- **Cryptography:** Protecting data at rest and in transit
- **Sandboxing:** Isolating and testing environments
- **Application virtualisation & orchestration:** Optimising resource utilisation
- **API security:** Securing application interfaces
- **Multi-tenancy:** Navigating shared resources
- **Supplemental security components:** layered defence

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CRYPTOGRAPHY - THE FOUNDATION

- **Data at Rest Encryption:** Essential in shared cloud environments to protect against unauthorised access, even if a physical disk is compromised.
- **Data in Transit Encryption:** Secures data as it travels across networks, preventing eavesdropping and man-in-the-middle attacks. TLS, the successor to SSL, encrypting communication between your browser and the cloud server.
- **Key Management:** The cornerstone of any encryption scheme. If your keys are compromised, your encrypted data is vulnerable. Secure key storage and rotation are paramount.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SANDBOXING

- **Isolation:** Sandboxes create isolated environments, preventing any issues within the sandbox from affecting the broader system. Imagine a dedicated testing lab where experiments can be conducted without the risk of contaminating the main research facility.
- **Testing and Analysis:** Ideal for testing new code, analysing malware, or experimenting with configurations without impacting production systems.
- **Cloud-Native Sandboxing:** Cloud platforms excel at providing on-demand, ephemeral sandboxes, allowing for rapid iteration and experimentation.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

APPLICATION VIRTUALISATION & ORCHESTRATION

- **Application Virtualisation:** Runs applications in an isolated environment without virtualising the entire operating system. This leads to increased portability and more efficient resource utilisation compared to traditional virtual machines.
- **Containerisation (Docker):** Bundles an application with its libraries and dependencies into a container. These containers are lightweight and highly portable.
- **Orchestration (Kubernetes):** Manages and scales clusters of containers. Kubernetes handles tasks like deployment, scaling, and load balancing, ensuring your containerised applications run smoothly.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

API SECURITY: PROTECTING THE GATEWAY

- **APIs:** Enable communication between different applications. They are the gateways through which data and functionality are exchanged.
- **RESTful APIs:** A popular architectural style for building web APIs. They use standard HTTP methods (GET, POST, PUT, DELETE) to interact with resources.
- **SOAP APIs:** A more formal protocol for exchanging structured information. They use XML and are often preferred for enterprise applications requiring robust messaging.
- **API Security Best Practices:** Authentication, authorisation, input validation, rate limiting, and logging.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

MULTI-TENANCY

- **Shared Resources:** Multiple customers share the same underlying infrastructure (servers, storage, network). This is a core economic driver of cloud computing.
- **Logical Isolation:** Crucial to prevent one tenant from accessing another tenant's data. Think of it like apartments in a building – you share the building, but your apartment is isolated from your neighbours.
- **Security Considerations:** Data segregation, access control, and robust security practices are essential to maintain tenant isolation and prevent data breaches.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SUPPLEMENTAL SECURITY COMPONENTS

- **Web Application Firewalls (WAFs):** Protect web applications from common attacks like SQL injection and cross-site scripting. They act like a shield, inspecting incoming traffic and blocking malicious requests.
- **Database Activity Monitoring (DAM):** Monitors database activity for suspicious behaviour, helping to detect insider threats or compromised accounts.
- **API Gateways:** Manage and secure APIs, providing authentication, authorisation, rate limiting, and other security features.
- **Cloud Access Security Brokers (CASBs):** Monitor and control access to cloud applications, ensuring compliance with security policies.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

SUPPLEMENTAL SECURITY COMPONENTS

- **Web Application Firewalls (WAFs):** Protect web applications from common attacks like SQL injection and cross-site scripting. They act like a shield, inspecting incoming traffic and blocking malicious requests.
- **Database Activity Monitoring (DAM):** Monitors database activity for suspicious behaviour, helping to detect insider threats or compromised accounts.
- **API Gateways:** Manage and secure APIs, providing authentication, authorisation, rate limiting, and other security features.
- **Cloud Access Security Brokers (CASBs):** Monitor and control access to cloud applications, ensuring compliance with security policies.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

SUMMARY

- Cloud application architecture requires a holistic approach, considering all aspects of security.
- Understanding the common components and implementing robust security practices is essential for building resilient and secure cloud solutions.
- Continuous monitoring and improvement are key to maintaining a strong security posture in the ever-evolving cloud landscape.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://www.cccsp.com)

CLOUD SECURE SDLC

Mbong Hudson
Infrastructure Engineer - CCNP, AWS, CISSP

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

INTRODUCTION TO CLOUD-SECURE SDLC

- The software development lifecycle (SDLC) is essential for ensuring security and functionality in applications.
- SDLC maps software creation from idea to decommissioning.
- Organisations use SDLC to maintain consistency, improve planning, and streamline workflows.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

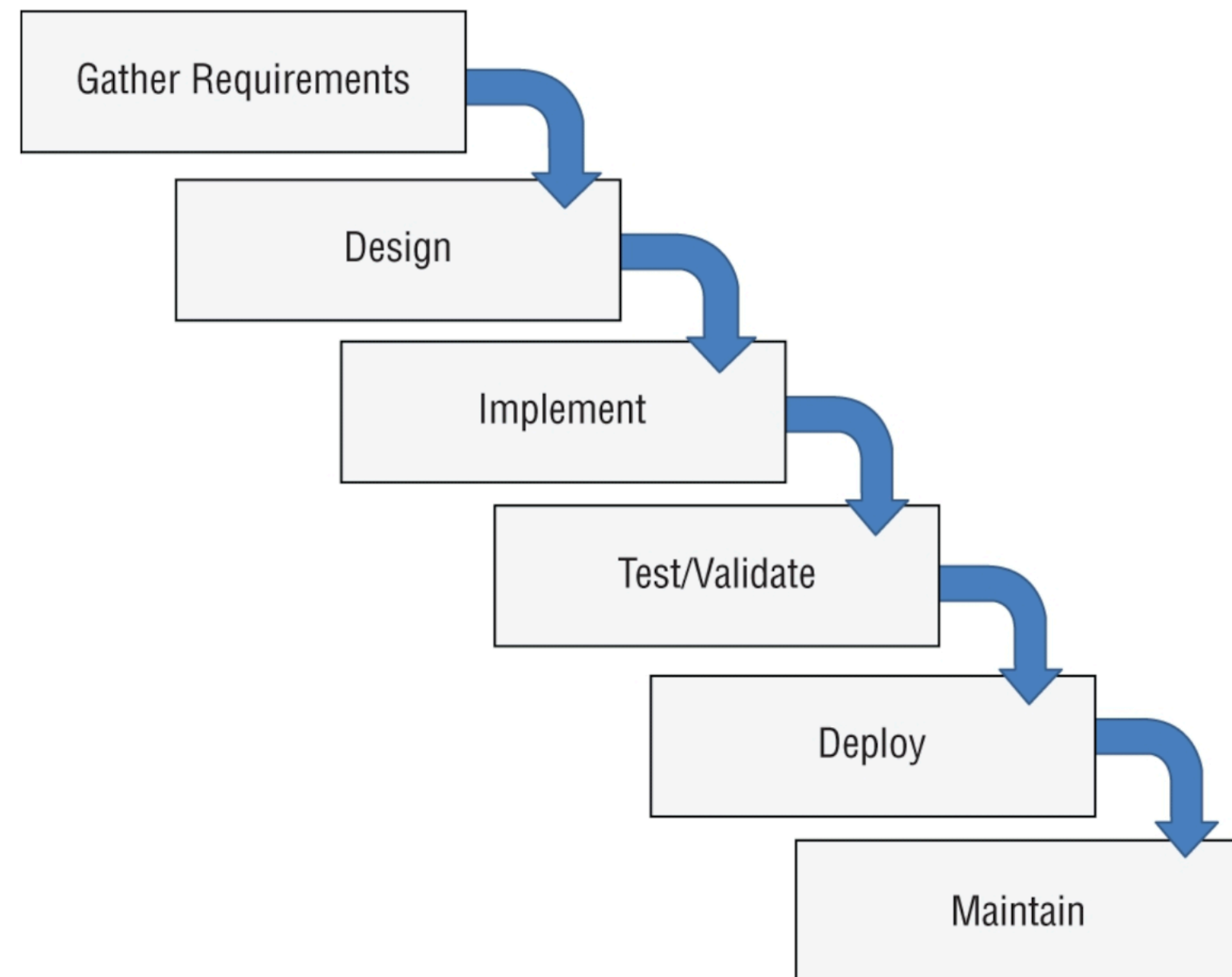
KEY PHASES IN THE SDLC

1. **Planning:** Define project feasibility, scope, and costs.
2. **Requirements Definition:** Gather customer needs and desired improvements.
3. **Design:** Develop functionality, architecture, integration, and data flow.
4. **Coding:** Write and test software components.
5. **Testing:** Conduct formal validation and user acceptance testing (UAT) .
6. **Deployment & Training:** Implement software and train users.
7. **Maintenance & Support:** Patch, update, and modify the application.
8. **Decommissioning:** Retire outdated software and manage data disposal.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SOFTWARE DEVELOPMENT MODELS

- **Waterfall:** Define project feasibility, scope, and costs.

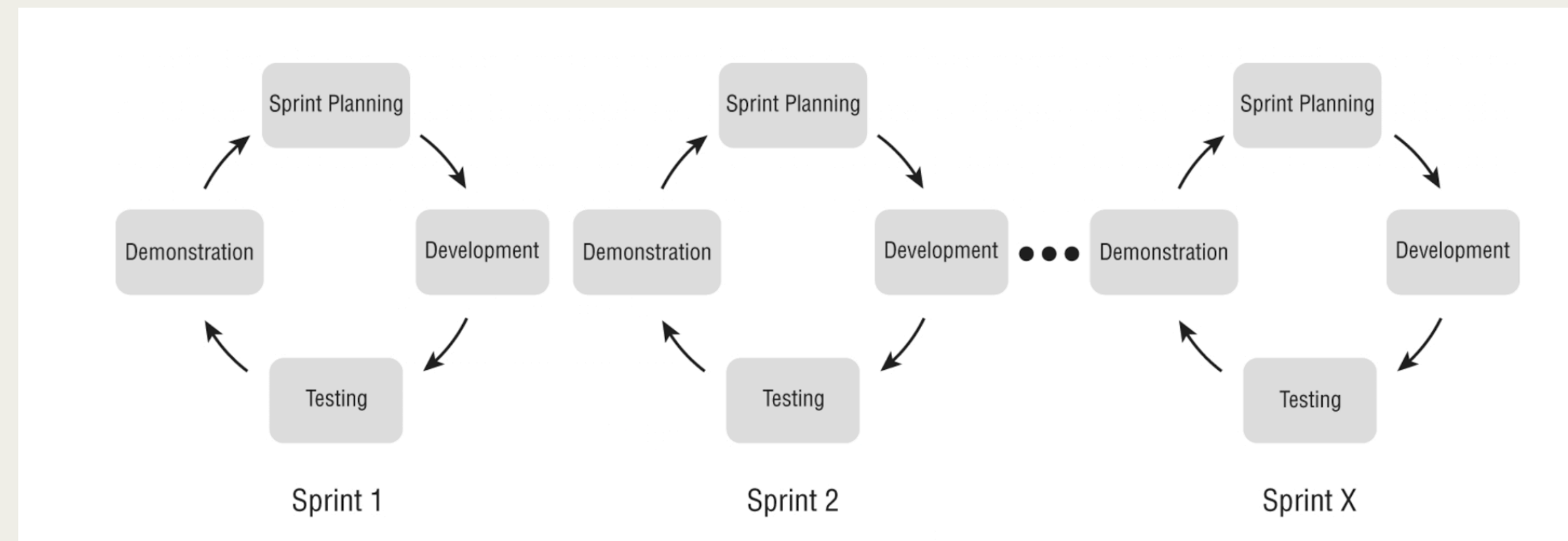


FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

SOFTWARE DEVELOPMENT MODELS

- **Agile:**

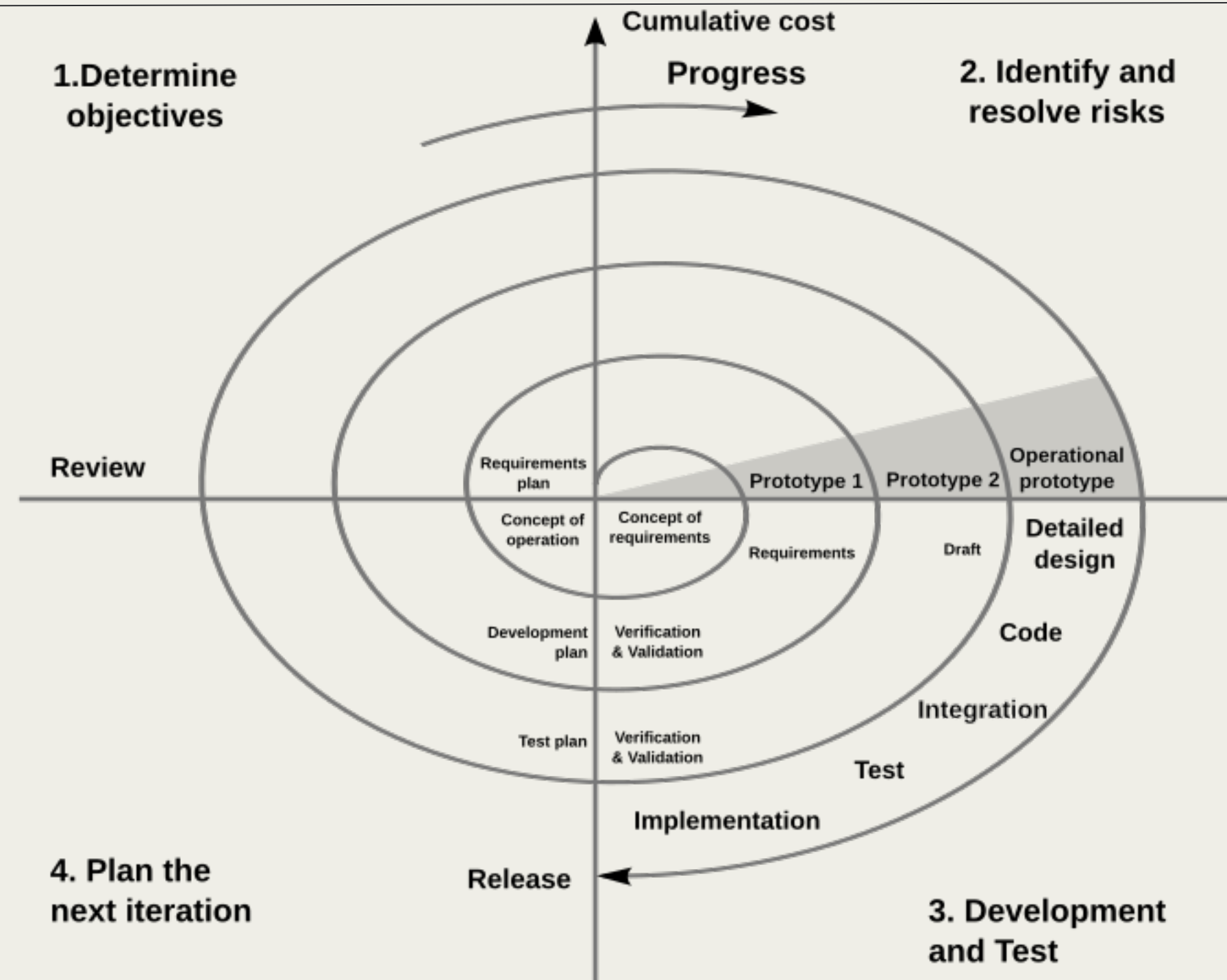
- Focuses on iterative development and adaptability.
- Emphasises collaboration over rigid documentation.
- Uses sprints for continuous progress.
- Encourages customer feedback and iterative improvements.



FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SOFTWARE DEVELOPMENT MODELS

- **Spiral:** Combines iterative development with risk assessment.



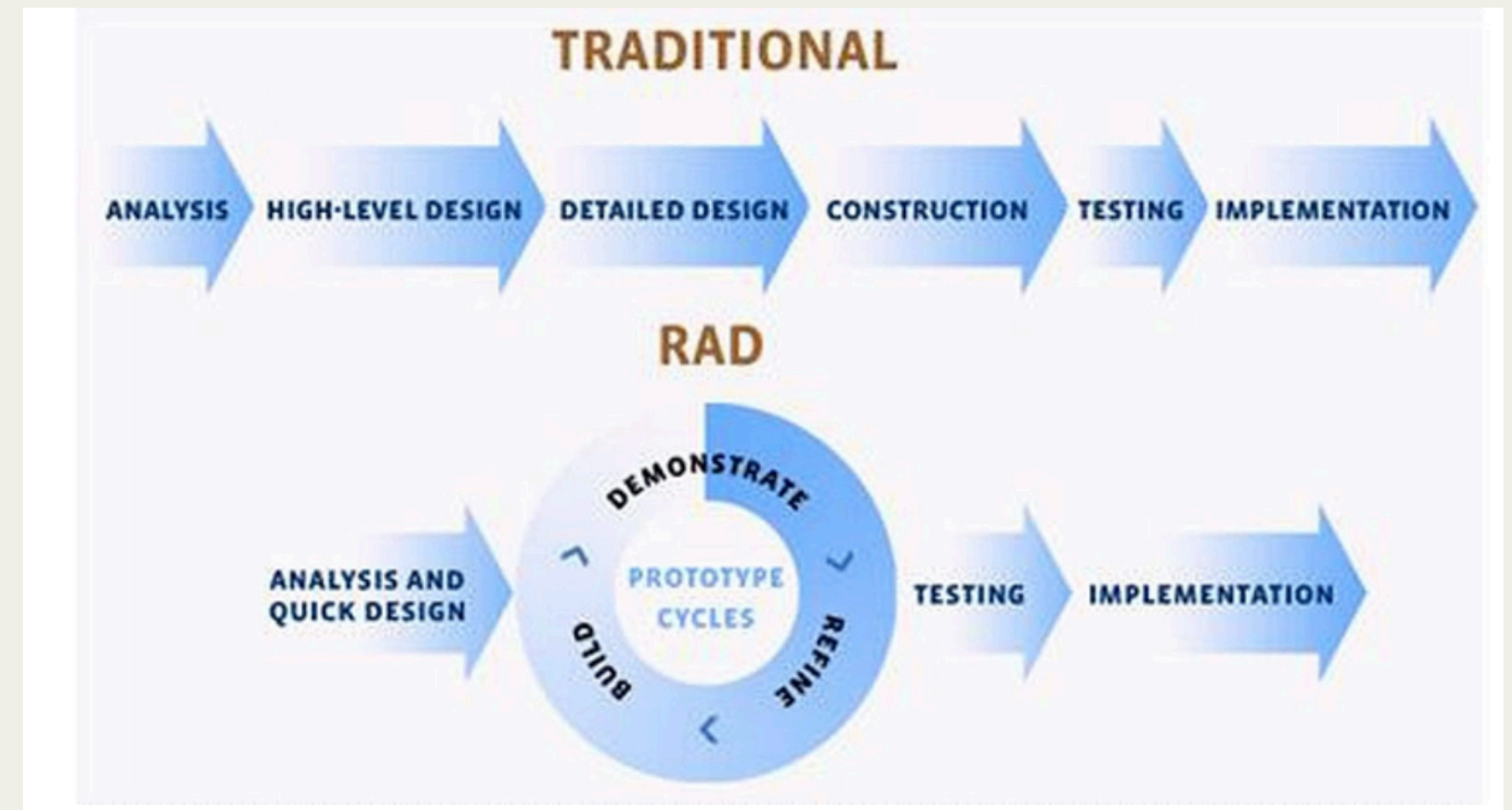
FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

SOFTWARE DEVELOPMENT MODELS

- **Rapid Application**

Development (RAD):

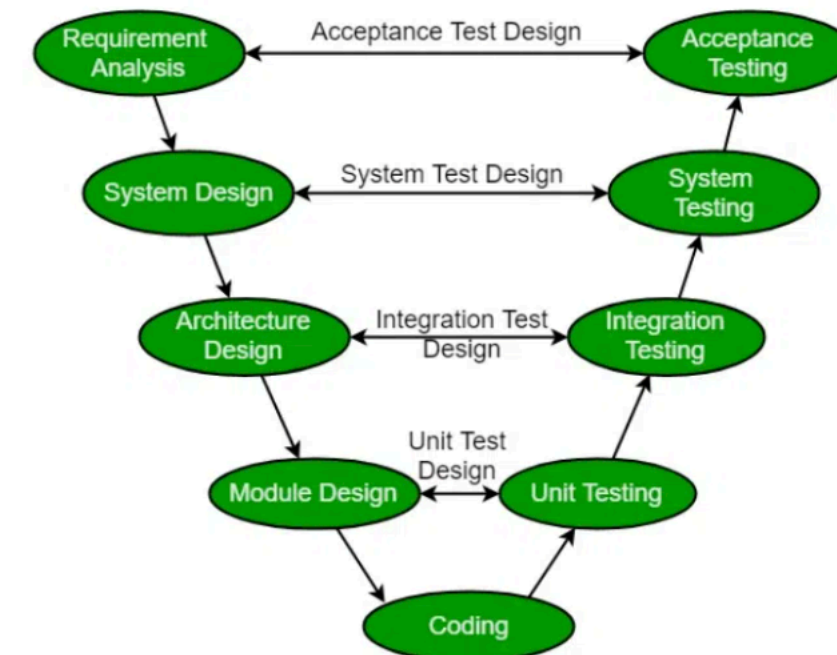
Prototype-driven with minimal planning.



FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SOFTWARE DEVELOPMENT MODELS

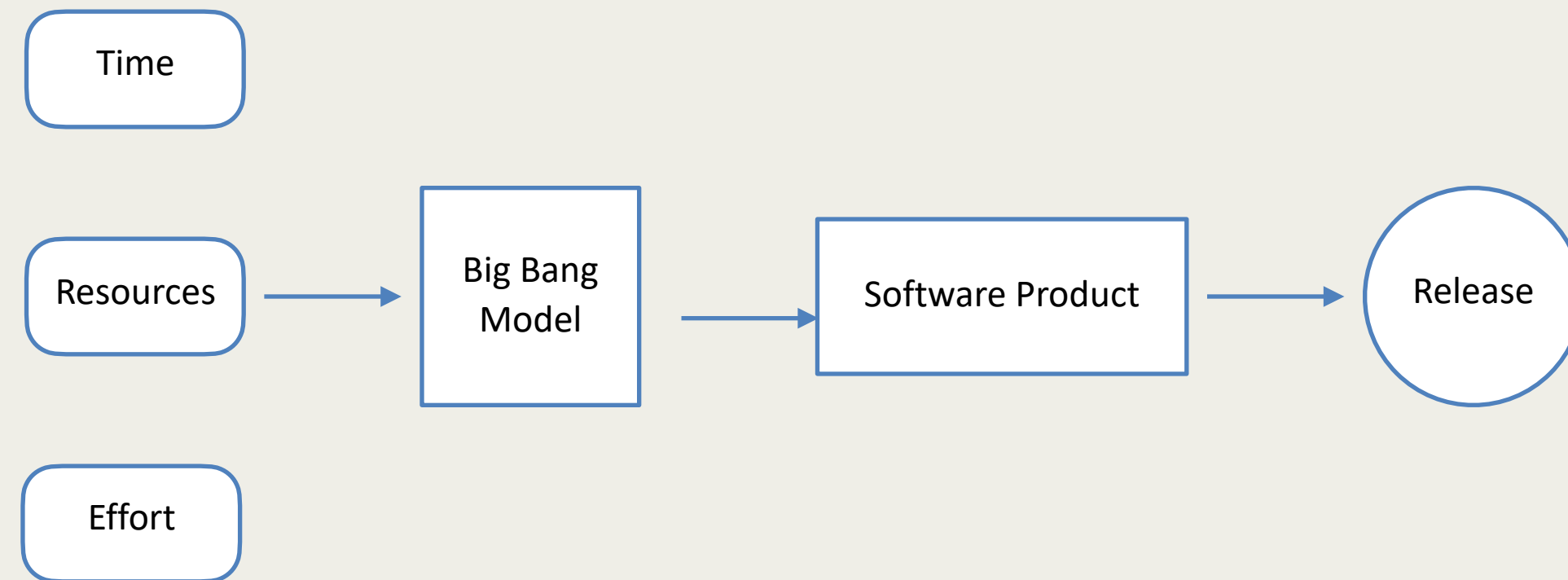
- **V-Model:** Paired testing with each development phase.



FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SOFTWARE DEVELOPMENT MODELS

- **Big Bang:** No formal planning, typically used for personal projects.



FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SOFTWARE DEVELOPMENT MODELS

- **Waterfall:** Sequential, structured, and ideal for fixed-scope projects.
- **Agile:** Iterative, adaptive, and focused on collaboration and flexibility.
- **Spiral:** Combines iterative development with risk assessment.
- **Rapid Application Development (RAD):** Prototype-driven with minimal planning.
- **V-Model:** Paired testing with each development phase.
- **Big Bang:** No formal planning, typically used for personal projects.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SECURE CODING AND THE SDLC

Secure coding practices:

- **Definition:** A set of guidelines and techniques to write software that minimises security vulnerabilities. Prevent flaws like injection attacks, buffer overflows, and insecure authentication.
- **Purpose:** Prevent flaws like injection attacks, buffer overflows, and insecure authentication.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SECURE CODING AND THE SDLC

OWASP Top 10:

- **Definition:** A list of the ten most critical web application security risks, updated regularly.
- **Purpose:** Raise awareness and help organizations prioritise mitigation strategies.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SECURE CODING AND THE SDLC

SANS Top 25:

- **Definition:** A ranking of the most dangerous software errors that can lead to serious vulnerabilities.
- **Purpose:** Guide developers on eliminating the most impactful software security flaws.

Improper input validation	Vulnerable components	Failure to protect data in transit
Failure to preserve integrity	Information leakage	Reliance on untrusted inputs
Improper error handling	Insecure configuration	Insufficient logging and monitoring
Weak authentication	Insufficient data protection	Failure to enforce default deny
Missing authorisation	Missing security updates	Cross-site scripting (XSS)
Broken cryptography	Insecure randomness	SQL injection
Insecure deserialisation	Race conditions	Cross-site Request Forgery (CSRF)
Improper access control	Improper privilege management	Path traversal
Resource exhaustion		

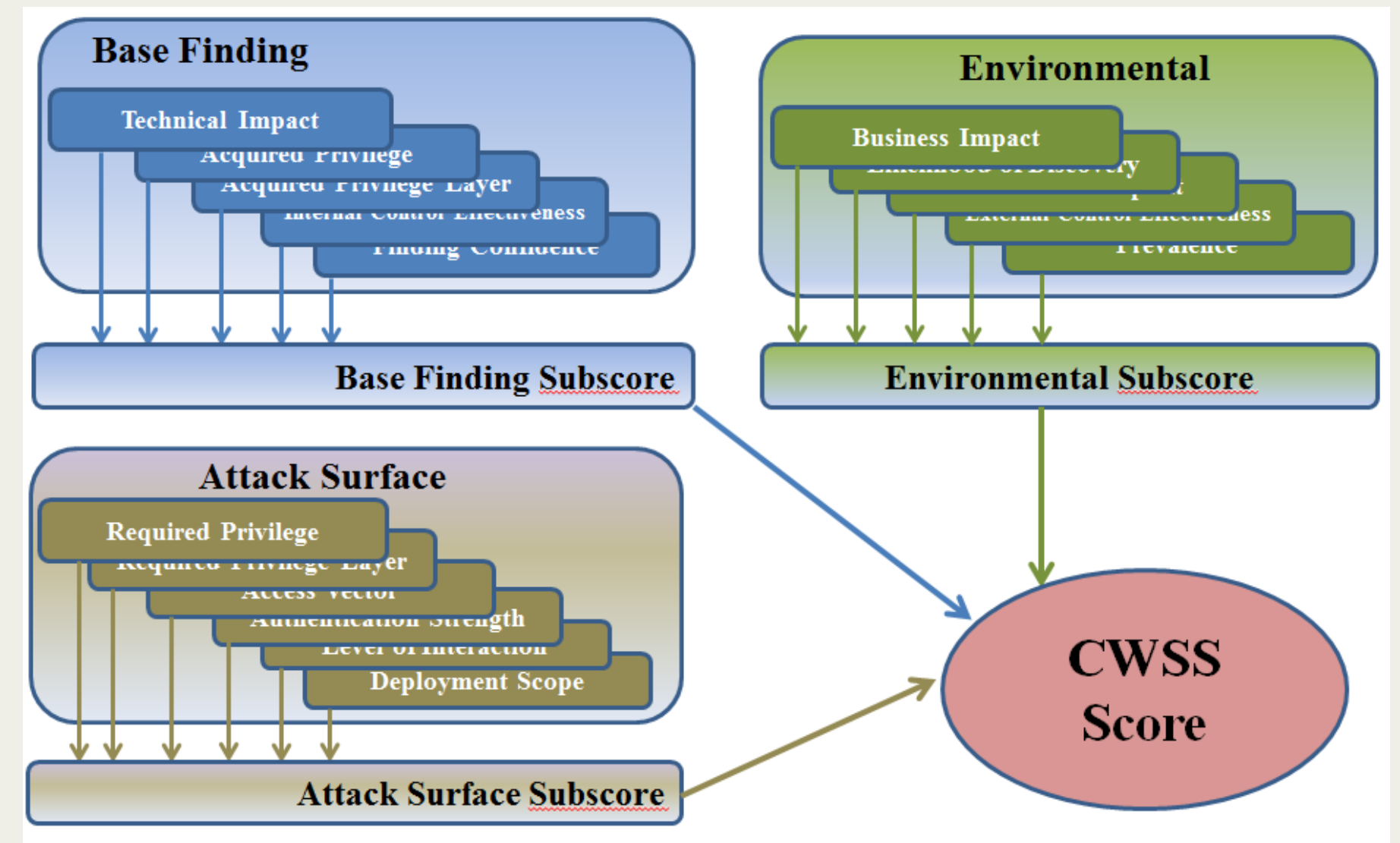
FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SECURE CODING AND THE SDLC

Common Weakness Scoring System

(CWSS) :

- **Definition:** A framework to assess and prioritise security weaknesses based on severity, exploitability, and impact.
- **Purpose:** Provide a standardised risk evaluation for software security.



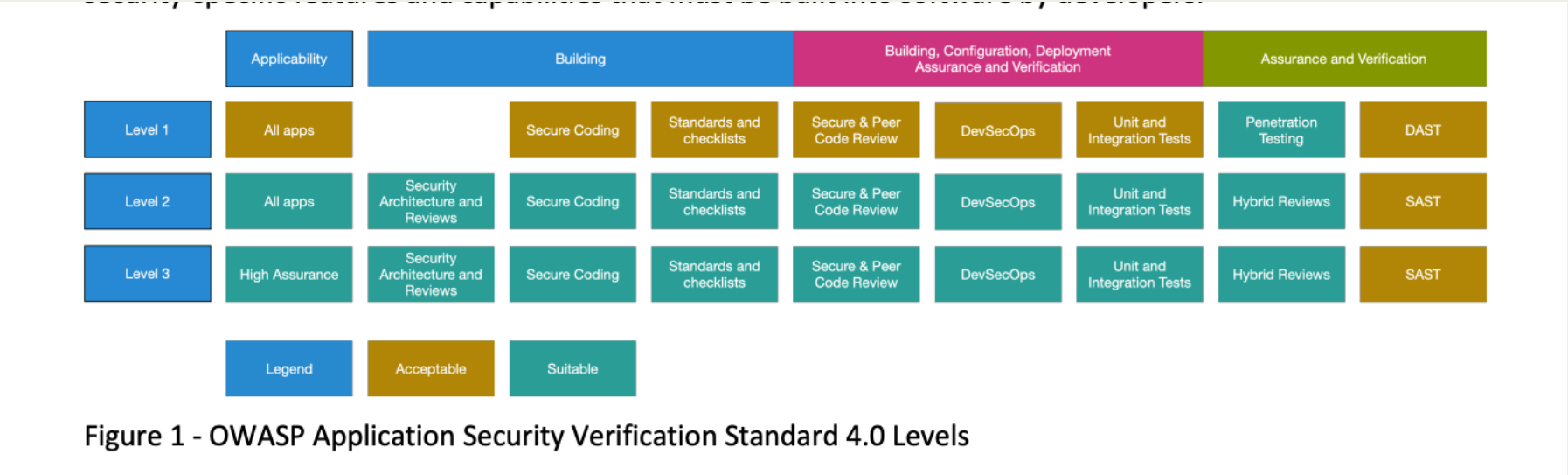
FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SECURE CODING AND THE SDLC

Application Security Verification

Standard (ASVS) :

- **Definition:** A framework outlining security requirements for verifying application security.
- **Purpose:** Ensure applications meet specific security quality benchmarks.



SECURE CODING AND THE SDLC

SAFECode:

- **Definition:** An industry-led initiative that promotes best practices for software security.
- **Purpose:** Help organizations implement secure development methodologies.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CONFIGURATION MANAGEMENT & VERSIONING

- Versioning tracks software updates
(e.g., 11.3.1 for major.minor.patch).
- Software Bill of Materials (SBOM) lists components.
- Configuration management ensures security and stability.
- Centralised cloud-based configurations improve DevOps efficiency.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SUMMARY

- SDLC ensures structured, secure, and efficient software development.
- Selecting the right SDLC model depends on project needs.
- Secure coding and configuration management are essential.
- Continuous improvement and adaptation drive long-term success.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://www.cissp-substack.com)

THREAT MODELLING IN APPLICATION SECURITY

Mbong Hudson
Infrastructure Engineer - CCNP, AWS, CISSP

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

INTRODUCTION TO THREAT MODELLING

- Applications are tested at various stages: during development, pre-deployment, and throughout their lifecycle.
- Effective security testing requires familiarity with threat modelling techniques.
- This tutorial explores four major threat modelling processes: **STRIDE**, **DREAD**, **ATASM**, and **PASTA**.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

WHAT IS THREAT MODELLING?

- Threat modelling is a structured approach to identifying, evaluating, and mitigating security threats.
- It helps developers and security professionals proactively address vulnerabilities.
- Integrates into the SDLC to enhance security before deployment.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

STRIDE

- Developed by Microsoft to categorise threats based on attributes.
- Helps developers identify vulnerabilities early in the SDLC.
- STRIDE stands for:
 - **Spoofing** – Impersonation threats.
 - **Tampering** – Unauthorised data modifications.
 - **Repudiation** – Lack of transaction traceability.
 - **Information Disclosure** – Exposure of sensitive data.
 - **Denial of Service (DoS)** – Disrupting application availability.
 - **Elevation of Privilege** – Unauthorised access escalation.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

STRIDE BREAKDOWN

- **Spoofing:** Can an attacker disguise their identity?
- **Tampering:** Can a user modify data without authorisation?
- **Repudiation:** Can a user deny performing an action?
- **Information Disclosure:** Can sensitive data be exposed?
- **Denial-of-Service:** Can the system be overloaded or shut down?
- **Elevation of Privilege:** Can unauthorised users gain higher access?

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://www.cccsp.com)

STRIDE BREAKDOWN

- **Spoofing:** Can an attacker disguise their identity?
- **Tampering:** Can a user modify data without authorisation?
- **Repudiation:** Can a user deny performing an action?
- **Information Disclosure:** Can sensitive data be exposed?
- **Denial-of-Service:** Can the system be overloaded or shut down?
- **Elevation of Privilege:** Can unauthorised users gain higher access?

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

DREAD

- Also developed by Microsoft but later deprecated.
- Assesses security threats by assigning numerical scores.
- Five risk categories:
 - **Damage:** Severity of the impact.
 - **Reproducibility:** Ease of attack replication.
 - **Exploitability:** Ease of exploitation.
 - **Affected Users:** Scope of impact.
 - **Discoverability:** Ease of threat identification.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://www.substack.com/p/ccsp)

ATASM - ARCHITECTURAL THREAT ANALYSIS

- Focuses on architecture and security controls.
- Steps:
 1. Understand system architecture.
 2. Identify threat agents and their objectives.
 3. Analyse attack surfaces.
 4. Review security controls and mitigate risks.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://www.substack.com/p/ccsp)

PASTA - ATTACK SIMULATION & ANALYSIS

- A seven-stage framework focusing on attacker perspective.
- Stages:
 1. Define business objectives.
 2. Define technical scope.
 3. Identify applications and controls.
 4. Perform threat analysis.
 5. Detect vulnerabilities.
 6. Model attacks.
 7. Assess risk and implement countermeasures.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

COMPARING THREAT MODELLING FRAMEWORKS

- **STRIDE:** Identifies vulnerabilities early in development.
- **DREAD:** Provides a risk assessment scoring system.
- **ATASM:** Focuses on architectural security.
- **PASTA:** Uses an attacker's perspective for threat analysis.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

THE IMPORTANCE OF THREAT MODELLING

- Integrating threat modelling improves security.
- Each framework offers unique benefits.
- Security should be embedded throughout the SDLC.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

QUALITY ASSURANCE (QA), TESTING TECHNIQUES

Mbong Hudson
Infrastructure Engineer - CCNP, AWS, CISSP

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

INTRODUCTION

- Overview of Quality Assurance (QA) and Testing
- Ensuring software meets requirements
- Combination of automated and manual testing techniques

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

THE QA TESTING PROCESS

- Reviews, testing, and reporting
- Involves multiple roles in an organization
- QA staff, developers, and end-users participation

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

FUNCTIONAL VERSUS NON-FUNCTIONAL TESTING

- **Functional Testing:**

- Ensuring the software meets requirements

- **Types:** Integration, Regression, User Acceptance Testing

- **Nonfunctional Testing:**

- Evaluating performance and stability

- **Types:** Load Testing, Stress Testing

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SOFTWARE TESTING METHODOLOGIES

- Static Application Testing: Reviewing source code
- Dynamic Application Testing: Running the application
- Interactive Application Security Testing (IAST)

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

WHITE BOX, BLACK BOX, GREY BOX TESTING

- **White Box Testing:** Full knowledge of system and code
- **Black Box Testing:** No prior knowledge of system
- **Grey Box Testing:** Partial knowledge of system

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

ABUSE CASE TESTING

- Identifies unintended uses of software
- Exploits weaknesses and coding flaws
- Helps improve security features and controls

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SOFTWARE COMPOSITION ANALYSIS (SCA)

- Tracks software components and dependencies
- Commonly used for open-source software
- Identifies vulnerabilities in third-party components

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SUPPLY CHAIN MANAGEMENT & LICENSING

- Managing software vendors and supply chain risks
- Ensuring proper software licensing
- Compliance with legal and operational requirements

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CONCLUSION

- Importance of QA and testing
- Ensuring software reliability and security
- Continuous improvement in testing processes

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

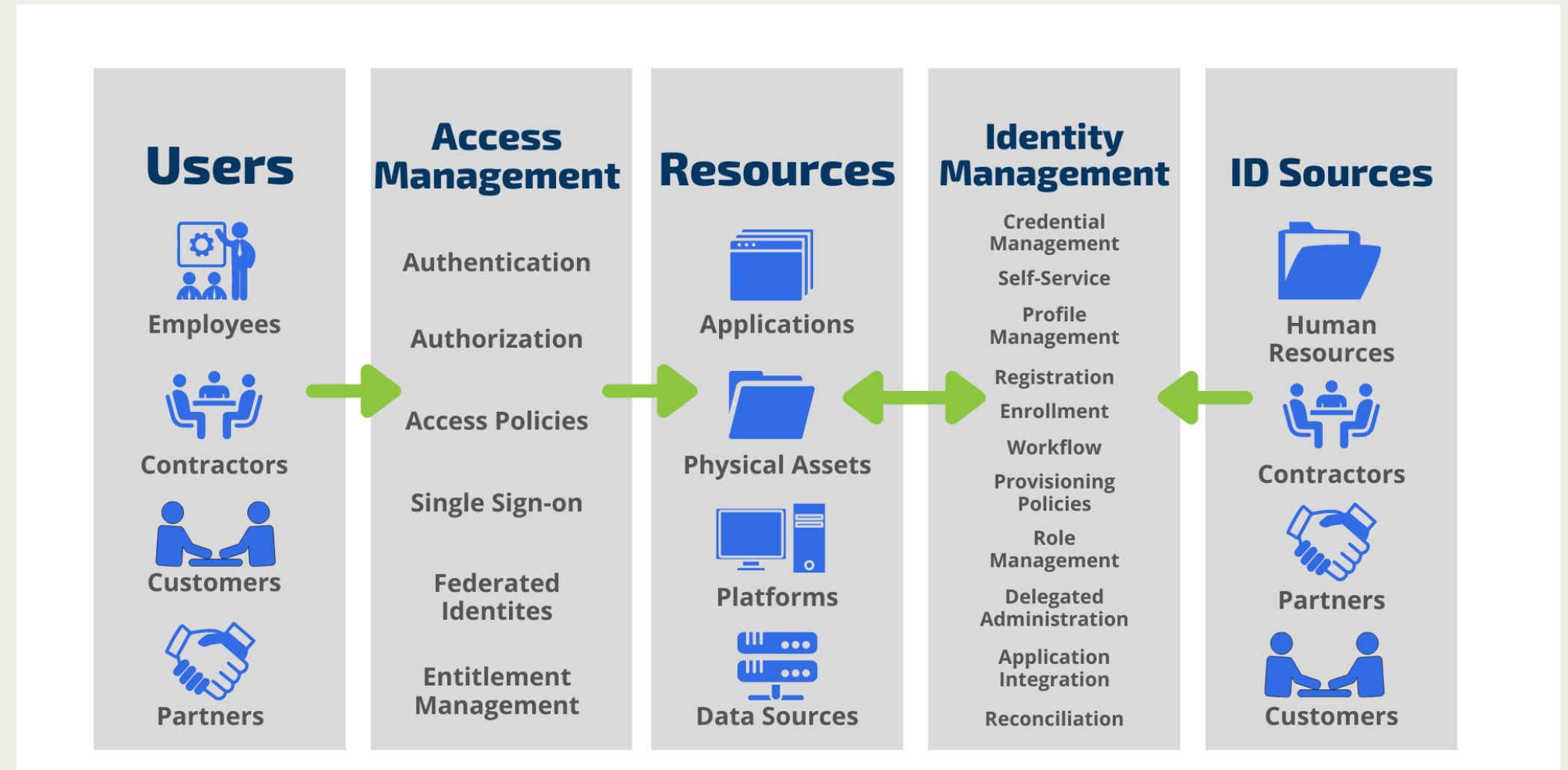
IDENTITY AND ACCESS MANAGEMENT (IAM)

Mbong Hudson
Infrastructure Engineer - CCNP, AWS, CISSP

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

INTRODUCTION

- Core principles
- Components
- Best practices



FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

WHAT IS IDENTITY AND ACCESS MANAGEMENT?

- People, processes, and technologies for managing digital identities.
- Full lifecycle management of identities.
- Key components: identification, authentication, authorisation, monitoring, and lifecycle management.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

KEY COMPONENTS OF IAM

- **Identification:** Establishing a unique identity.
- **Authentication:** Verifying the identity.
- **Authorisation:** Granting access based on permissions.
- **Monitoring:** Tracking and logging access.
- **Lifecycle Management:** Managing identities from creation to deletion.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

IDENTITY MANAGEMENT

- **Provisioning:** Creating unique identity assertions (user IDs).
- **Password management:** Issuing and recording passwords.
- **Record keeping.**



FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

ACCESS MANAGEMENT

- **Authentication:** Verifying user identity.
- **Authorisation:** Determining access permissions.
- **Policy Management:** Enforcing access policies.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

FEDERATION

- **Definition:** A system of trust between organizations to share user identity information and access rights.
- **Benefits:** Streamlined access, reduced administrative overhead, improved user experience.
- **Nuances:**
 - **Trust models:** Web of Trust (peer-to-peer) vs. Trusted Third Party (centralised).
 - **Standards:** SAML, OAuth, OpenID Connect.
 - **Attribute exchange:** Controlling what information is shared and how.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

IDENTITY REPOSITORIES

- **Definition:** A directory service or database that stores and manages user identities and attributes.
- **Types:** LDAP directories, cloud-based identity platforms, databases.
- **Nuances:**
 - **Attribute management:** Defining and controlling user attributes.
 - **Schema design:** Structuring identity data for efficiency and interoperability.
 - **Synchronisation:** Ensuring data consistency across systems.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CLOUD IDENTITY AND ACCESS CONTROL

- **User Access: Balancing Convenience and Security:**

- Cloud provider IAM (e.g., AWS IAM, Azure AD, Google Cloud IAM) vs. federated identities.
- Fine-grained access control (least privilege principle).

- **Examples:**

- Role-Based Access Control (RBAC) for granular permissions.
- Conditional Access Policies based on location, device, and risk.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://www.cccsp.org/substack)

CLOUD IDENTITY AND ACCESS CONTROL

- **Privilege Access: Safeguarding Administrative Accounts:**

- Just-in-Time (JIT) access for temporary privilege elevation.
- Multi-Factor Authentication (MFA) enforcement.
- Session recording and auditing.

- **Examples:**

- Using tools like HashiCorp Vault for dynamic secrets and temporary credentials.
- Implementing Privileged Access Management (PAM) solutions.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CLOUD IDENTITY AND ACCESS CONTROL

- **Service Access: Securing Machine-to-Machine Communication:**
 - Service accounts and managed identities.
 - API key management and rotation.
 - Mutual TLS (mTLS) for secure service-to-service communication.
- **Examples:**

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

CLOUD IDENTITY AND ACCESS CONTROL

- **Service Access: Securing Machine-to-Machine Communication:**
 - **Examples:**
 - **Secrets Management in Kubernetes:** Using Kubernetes Secrets or external secret stores like HashiCorp Vault or cloud provider secret managers to manage sensitive information used by containerised applications.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CLOUD IDENTITY AND ACCESS CONTROL

- **Service Access: Securing Machine-to-Machine Communication:**
 - **Examples:**
 - **CI/CD Pipeline Secrets:** Securely injecting API keys, database credentials, and other secrets into CI/CD pipelines using tools like Jenkins Credentials Plugin, GitHub Actions Secrets, or cloud-native CI/CD solutions.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

CLOUD IDENTITY AND ACCESS CONTROL

- **Service Access: Securing Machine-to-Machine Communication:**

- **Examples:**

- **AWS Secrets Manager/Azure Key Vault/Google Secret Manager:**

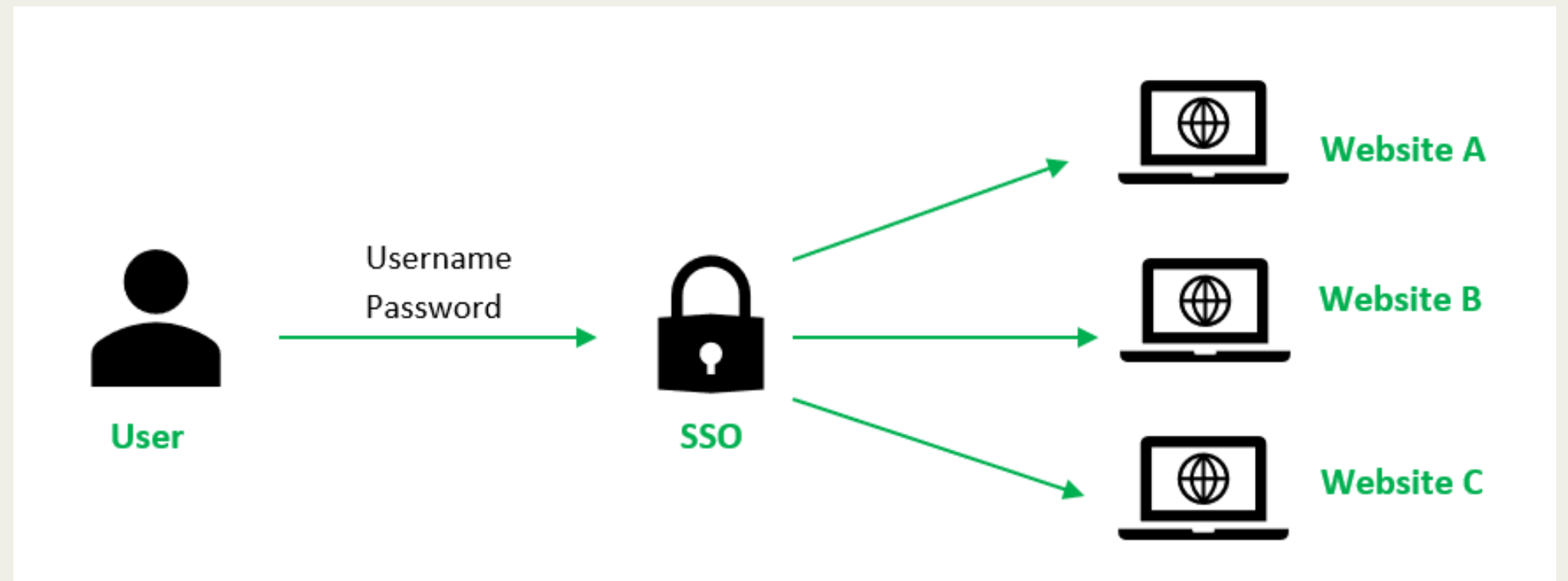
- Centralised services for storing, rotating, and managing secrets, with integration into cloud applications and services.

- **Using managed identities for cloud resources,** so that they do not need to use long lived API keys.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

SINGLE SIGN-ON (SSO)

- One-time login for access to multiple resources.
- Simplified user experience.
- Security considerations:
Centralised risk.



FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

IDPs AND FEDERATED IDENTITY MANAGEMENT

- **Identity Providers (IdPs):** The Authority on Identities:
 - **Definition:** Systems that create, maintain, and manage identity information for users and other entities.
 - **Functions:** Authentication, attribute provision, and identity lifecycle management.
 - **Examples:**



FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

IDPs AND FEDERATED IDENTITY MANAGEMENT

- **Identity Providers (IdPs):** The Authority on Identities:
 - **Examples:**
 - **Enterprise IdPs:** Microsoft Active Directory, Okta, Ping Identity.
 - **Consumer IdPs:** Google Identity, Facebook Login, Apple ID.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

IDPs AND FEDERATED IDENTITY MANAGEMENT

- Identity Providers (IdPs):
 - Nuances:
 - **Protocol Support:** SAML, OAuth 2.0, OpenID Connect.
 - **Attribute Mapping:** Translating identity attributes between systems.
 - **Strong Authentication:** Enforcing MFA and other advanced authentication methods.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

IDPs AND FEDERATED IDENTITY MANAGEMENT

- **Federated Identity Management: Enabling Cross-Domain Trust:**
 - **Definition:** A system that allows users to access resources in multiple domains using a single set of credentials.
 - **Benefits:** Enhanced user experience, reduced password fatigue, and streamlined access management.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

IDPs AND FEDERATED IDENTITY MANAGEMENT

- **Federated Identity Management: Enabling Cross-Domain Trust:**
 - **Trust Models:**
 - **Web of Trust:** Decentralised trust between participating organizations. Scalability challenges.
 - **Trusted Third Party:** Centralised trust through a common IdP. Simplified management, single point of failure.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

IDPs AND FEDERATED IDENTITY MANAGEMENT

- **Federated Identity Management: Enabling Cross-Domain Trust:**
 - **Federation Protocols:**
 - **SAML (Security Assertion Markup Language)**: For web-based SSO.
 - **OAuth 2.0**: For authorisation and API access.
 - **OpenID Connect (OIDC)**: An identity layer built on top of OAuth 2.0.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

MULTI-FACTOR AUTHENTICATION (MFA)

- Combines multiple authentication factors (something you know, have, or are).
- Increased security against unauthorised access.
- Required for cybersecurity insurance and modern applications.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://www.substack.com/p/ccsp)

COMMON THREATS TO IAM IN THE CLOUD

- Lost or exposed credentials.
- Improper permissions.
- Lack of monitoring and alerting.
- IAM misconfigurations.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

ZERO TRUST

- **Core Principles of Zero Trust:**

- **"Never trust, always verify":** Explicit verification of every user, device, and application.
- **Least privilege access:** Granting only the necessary permissions.
- **Micro-segmentation:** Dividing the network into smaller, isolated segments.
- **Continuous monitoring and logging:** Real-time visibility into network activity.
- **Assume breach:** Designing systems with the understanding that a breach is inevitable.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

ZERO TRUST

- **Implementation Considerations:**

- **Phased approach:** Starting with high-risk areas and gradually expanding.
- **Policy-driven enforcement:** Automating access control and security policies.
- **User experience:** Balancing security with usability.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
CCSP.SUBSTACK.COM

ZERO TRUST

- **Examples:**

- **Software-Defined Perimeter (SDP):** Creating secure, virtual perimeters around applications.
- **Context-Aware Access:** Granting access based on user, device, and location context.
- **Behavioural Analytics:** Detecting anomalous user and device behaviour.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)

ZERO TRUST

- **Benefits:**

- Reduced attack surface.
- Improved threat detection and response.
- Enhanced data protection.
- Increased security agility.

FOR SLIDES, SUPPLEMENTARY LABS,
QUIZZES AND ARTICLES,
[CCSP.SUBSTACK.COM](https://ccsp.substack.com)